

Ferramenta Baseada em Bash para Detecção de Intrusão em Servidores e Endurecimento do Sistema

- Introdução

Em resposta à crescente necessidade de avaliações de segurança automatizadas e repetíveis em servidores Linux, desenvolvi um script Bash abrangente que consolida múltiplas verificações críticas de segurança em um único fluxo de trabalho eficiente. O script foi projetado para ser executado regularmente, seja manualmente ou por meio de um cron job, fornecendo uma visão clara da postura de segurança do servidor. O script prioriza um sequenciamento lógico: primeiro verifica atualizações/upgrades pendentes do sistema, depois enumera os serviços de rede, executa varreduras de rootkit e malware e, finalmente, analisa os logs de autenticação. Cada comando é prefixado com “sudo” para garantir os privilégios necessários, e o script lida graciosamente com ferramentas ausentes, exibindo instruções claras de instalação em vez de falhar abruptamente.

- Verificação de Atualizações do Sistema

O script começa atualizando as listas de pacotes usando “apt update” e “apt upgrade”. Esta etapa é fundamental porque muitos ataques exploram vulnerabilidades conhecidas que já foram corrigidas em versões mais recentes do software. Ao destacar pacotes que podem ser atualizados, o script alerta imediatamente o administrador para aplicar as atualizações de segurança antes de prosseguir com verificações mais profundas. Essa abordagem proativa garante que o servidor não seja avaliado enquanto executa código desatualizado e vulnerável, o que poderia produzir resultados enganosamente positivos das outras ferramentas de detecção.

- Enumeração de Rede e Serviços

Entender quais serviços estão expostos à rede é essencial para reduzir a superfície de ataque. O script usa “ss -tulpn” para exibir todas as portas TCP e UDP em escuta, juntamente com os nomes dos processos associados e seus PIDs. Isso revela quaisquer serviços inesperados ou não autorizados que um atacante possa ter instalado, como shells reversos, backdoors ou servidores web maliciosos. Além disso, se o Docker estiver instalado no sistema, o script executa “docker ps” para listar os contêineres em execução. Ambientes containerizados podem se tornar pontos de comprometimento se forem configurados com privilégios excessivos ou contiverem imagens vulneráveis; enumerá-los ajuda a manter a visibilidade tanto nas cargas de trabalho do host quanto dos contêineres.

Deteção de Rootkit e Malware

Para descobrir ameaças persistentes ocultas, o script emprega duas ferramentas especializadas: rkhunter (Rootkit Hunter) e ClamAV. O rkhunter varre o sistema em busca de rootkits conhecidos, backdoors e outros artefatos maliciosos, comparando binários do sistema, módulos do kernel e arquivos de configuração com assinaturas confiáveis. O comando executa com a opção “--skip-keypress” para permitir execução totalmente automatizada sem interação do usuário. Após a varredura de rootkit, o script inicia uma verificação de malware em todo o sistema de arquivos usando o ClamAV. Antes da varredura, ele atualiza as definições de vírus com “freshclam” (se disponível) para garantir o uso das assinaturas mais recentes. A verificação é feita recursivamente no diretório raiz (/), com exclusões sensatas para sistemas de arquivos virtuais (/proc, /sys, /dev, /run) para evitar erros e reduzir o tempo de verificação. Quaisquer arquivos infectados são registrados no diretório /tmp/clamav_scan.log para análise posterior. Juntos, rkhunter e ClamAV fornecem uma defesa em camadas: detecção de rootkit baseada em assinaturas complementada por uma verificação de malware de amplo espectro.

- Análise de Autenticação e Logs

A seção final do script concentra-se na auditoria da atividade do usuário e dos eventos do sistema. Primeiramente, ele exibe as últimas 20 conexões bem-sucedidas usando “last -a”, seguidas pelas últimas 20 tentativas de login com falha usando “lastb”. Essas listas podem revelar padrões de ataques de força bruta, acesso não autorizado ou horários de login suspeitos. Em seguida, o script extrai as últimas 50 advertências do sistema a partir do journal usando “journalctl --priority=warning --since "24h ago"”, fornecendo um resumo conciso de erros recentes do kernel ou de serviços que possam indicar tentativas de comprometimento. Depois, ele pesquisa em /var/log/auth.log a string “Failed password” para mostrar as falhas de autenticação mais recentes, oferecendo uma visão imediata de ataques ativos. Ele também extrai comandos sudo recentes do mesmo log, permitindo que o administrador veja quais ações com privilégios elevados foram executadas recentemente. Por fim, o script consulta o “fail2ban” em detalhes: recupera a lista de todas as prisões ativas e itera sobre cada uma, exibindo o status da prisão, o filtro, as ações e os endereços IP atualmente banidos. Esse output granular do fail2ban é particularmente valiosa para avaliar se as defesas automatizadas estão bloqueando efetivamente as tentativas repetidas de intrusão.

- Conclusão

Este script Bash entrega uma avaliação de segurança completa e automatizada que pode ser executada em qualquer servidor Linux baseado em Debian. Ao combinar verificações de atualizações, enumeração de rede, detecção de rootkit, varredura de malware e análise abrangente de logs em uma única ferramenta, ele reduz significativamente o tempo e a experiência necessários para realizar auditorias de segurança regulares. O script é projetado para ambientes de produção, pois não é destrutivo, lida graciosamente com dependências ausentes e produz um output claro e acionável.